



Introducción al Marco Legal y Auditorías de Ciberseguridad



Con la colaboración:





Introducción a TISAX

Módulo 6

Introducción a TISAX

¿Qué es TISAX?

- **TISAX** (Trusted Information Security Assessment Exchange) es un sistema de **evaluación y reconocimiento mutuo de la seguridad de la información** desarrollado para cubrir las necesidades específicas de la **industria automotriz**, especialmente en Europa. Fue creado para evitar que cada empresa del sector realizara sus propias auditorías y certificaciones, estableciendo un **marco común y compartido**.
- El objetivo de TISAX es asegurar que los proveedores, fabricantes y socios compartan **un nivel homogéneo de ciberseguridad y protección de datos confidenciales**, especialmente en lo relativo a diseño, prototipos, conectividad de vehículos y producción.

Organismo responsable

- TISAX fue creado por la **Asociación Alemana de la Industria del Automóvil (VDA)**, por sus siglas en alemán) y es gestionado por la organización **ENX Association**.

ENX:

- Supervisa la plataforma TISAX.
- Acredita a los auditores.
- Asegura la calidad del proceso.
- Mantiene la **plataforma de intercambio de resultados TISAX**.

¿Cómo se aplica TISAX?

¿A quién va dirigido?

- TISAX es aplicable principalmente a:
- Proveedores y subcontratistas de fabricantes de automóviles.
- Empresas tecnológicas que acceden a datos confidenciales de OEMs.
- Consultoras o partners con acceso a planos, diseños, software, prototipos o datos personales de pruebas.
- Hoy en día, muchos fabricantes (como **BMW, VW, Mercedes-Benz**) exigen TISAX como condición para colaborar.

Alcance típico de aplicación:

- Diseño y desarrollo de componentes y sistemas electrónicos.
- Producción de piezas de automóviles.
- Procesamiento de datos de pruebas.
- Servicios en la nube o conectividad vehicular.
- Gestión de datos personales (empleados, conductores, etc.)

¿Cómo se implementa TISAX?

TISAX se basa en la norma **VDA ISA** (Information Security Assessment), alineada a **ISO/IEC 27001**, pero adaptada al sector. No es un estándar nuevo, sino una **forma sectorial de aplicar ISO 27001** con enfoque práctico.

Etapas clave de implementación:

- **Autoevaluación interna:** usando el cuestionario VDA ISA.
- **Solicitud en la plataforma ENX TISAX:** la empresa define el alcance, el nivel requerido, los lugares y objetivos de evaluación.
- **Auditoría externa por entidad acreditada:** revisión presencial o remota (según nivel).
- **Publicación del resultado** en la plataforma TISAX: accesible para otros socios bajo control del participante.
- **Reevaluación periódica:** normalmente cada 3 años, o antes si cambian los requisitos.

TISAX – Niveles de evaluación (Assessment Levels)

TISAX define **3 niveles de evaluación**, en función de la sensibilidad de la información y los requisitos del cliente:

Nivel	Tipo de evaluación	Destinatarios
AL1	Autoevaluación	Bajo riesgo (opcional)
AL2	Auditoría remota	Información confidencial, sin acceso físico
AL3	Auditoría in situ	Prototipos, diseño, I+D, alta confidencialidad

El nivel requerido lo define el cliente, no el proveedor.

TISAX – Dominios del modelo VDA ISA (áreas de control)

TISAX evalúa 3 dominios principales:

1. Seguridad de la información corporativa

- Políticas de seguridad
- Control de accesos
- Seguridad física y ambiental
- Gestión de incidentes
- Backup y continuidad

2. Protección de prototipos

- Control de accesos físicos y lógicos
- Gestión de visitantes
- Protección de pruebas
- Transporte seguro

TISAX – Dominios del modelo VDA ISA (áreas de control)

TISAX evalúa 3 dominios principales:

3. Protección de datos personales

- Evaluación de riesgos GDPR
- Gestión de consentimiento
- Confidencialidad
- Eliminación segura de datos

Cada dominio se subdivide en **módulos**, que reflejan requisitos concretos evaluables.

TISAX – Roles y Modelo de Roles

Rol	Descripción
Responsable de seguridad (CISO o similar)	Lidera la implementación del sistema
Coordinador TISAX	Gestiona el proceso de evaluación, comunicación con ENX
Auditor externo acreditado	Realiza la evaluación AL2/AL3
Dirección	Aprueba políticas, asigna recursos, supervisa cumplimiento
Responsables técnicos (OT/IT)	Aplican medidas de protección, segregación de redes, etc.

TISAX propone una estructura en la que:

- La **dirección garantiza recursos y compromiso.**
- El **equipo de seguridad lidera y coordina.**
- Las áreas técnicas (OT/IT) ejecutan medidas específicas.
- El **cliente OEM supervisa resultados TISAX y define el nivel requerido.**

TISAX

Factores de éxito

- Apoyo visible de la alta dirección.
- Enlace claro entre equipos de calidad, IT y OT.
- Comprensión precisa del nivel de evaluación requerido.
- Buen inventario de activos, riesgos y procesos.
- Formación continua del personal técnico.
- Simulación de la auditoría (preassessment) antes de la oficial.

Relación con otras normas y marcos

Norma	Relación con TISAX
ISO/IEC 27001	Base estructural del modelo TISAX (alineado al SGSI)
ISO/IEC 27017	Ciberseguridad en entornos cloud – aplicable a proveedores TISAX
ISO/SAE 21434	Seguridad en vehículos conectados – complementaria para fabricantes
GDPR	Obligaciones sobre datos personales incluidas en módulo 3
ISA/IEC 62443	Ciberseguridad OT – muy útil si hay sistemas industriales implicados
NIS2	Si aplica al sector, puede superponerse con exigencias de gobernanza y notificación

TISAX

Regulación y subcomités

- TISAX no es una **norma legal obligatoria**, sino un **estándar sectorial reconocido**. Sin embargo, muchos grandes OEMs exigen su cumplimiento, por lo que **se convierte en requisito contractual**.
- **Subcomités relevantes:**
- **Grupo de trabajo de seguridad de la VDA**
- **ENX TISAX Steering Committee**
- **Grupos de trabajo técnicos ENX–VDA–OEMs**

¿Qué NO es TISAX?

- No es una certificación ISO: **es un sistema de evaluación sectorial**.
- No hay certificado físico: el resultado se publica en la plataforma ENX.